

Guide Complet : Cryptographie pour Pentest (niveau entretien Synacktiv)

1. AES – Advanced Encryption Standard

Fiche d'identité

Élément	Valeur
Bloc	128 bits (16 octets)
Clé	128, 192 ou 256 bits
Rounds	10 (128), 12 (192), 14 (256)
Structure	Réseau de substitution-permutation
Sécurité	Basée sur la complexité algorithmique

Structure globale

Le chiffrement AES s'effectue en plusieurs rounds successifs. Chaque round applique quatre transformations à l'état interne (State) :

1. SubBytes : substitution non-linéaire avec une S-Box
2. ShiftRows : décalage de lignes (diffusion horizontale)
3. MixColumns : combinaison linéaire sur chaque colonne (diffusion verticale)
4. AddRoundKey : XOR avec la clé de round

Le dernier round ne fait pas MixColumns.

Détails des transformations

SubBytes

- Substitution non-linéaire (S-Box de Rijndael)
- Basée sur l'inverse multiplicatif dans $GF(2^8)$, suivi d'une transformation affine
- Appliquée octet par octet

ShiftRows

- Ligne 0 : inchangée
- Ligne 1 : décalée de 1 à gauche
- Ligne 2 : décalée de 2 à gauche
- Ligne 3 : décalée de 3 à gauche

MixColumns

- Multiplie chaque colonne de l'état par une matrice fixe dans $GF(2^8)$

Matrice :

```
[02 03 01 01]
[01 02 03 01]
[01 01 02 03]
[03 01 01 02]
```

Formule pour une colonne $[a_0, a_1, a_2, a_3]$:

```
[2*a0 XOR 3*a1 XOR a2 XOR a3,
 a0 XOR 2*a1 XOR 3*a2 XOR a3,
 a0 XOR a1 XOR 2*a2 XOR 3*a3,
 3*a0 XOR a1 XOR a2 XOR 2*a3]
```

AddRoundKey

- XOR état avec sous-clé du round

Key Schedule AES-128

- Dérive 11 clés de round à partir de la clé principale (10 rounds + initial)
- RotWord, SubBytes, ajout de Rcon
- Fonction déterministe, difficile à inverser

Vue d'ensemble AES-128

Initial AddRoundKey

Repeat 9 rounds:

SubBytes
ShiftRows
MixColumns
AddRoundKey

Final round:

SubBytes
ShiftRows
AddRoundKey

Modes de fonctionnement AES

ECB

- $C_i = E_K(M_i)$
- Chaque bloc est indépendant
- Problèmes : motifs visibles dans le chiffré

CBC

- $C_0 = IV$
- $C_i = E_K(M_i \text{ XOR } C_{i-1})$
- $D_i = D_K(C_i) \text{ XOR } C_{i-1}$
- Vulnérabilité : padding oracle

CTR

- Chiffrement par flot
- $S_i = AES_K(\text{Nonce} || \text{Counter}_i)$
- $C_i = M_i \text{ XOR } S_i$
- IV doit être unique

GCM

- Mode AEAD (chiffrement + authentification)
 - Utilise CTR + GHASH
 - Tag calculé avec $H = AES_K(0^{128})$
-

2. RSA

Génération des clés

1. Choisir p, q premiers
2. $n = p \times q$
3. $\phi(n) = (p-1)(q-1)$
4. Choisir e tel que $\gcd(e, \phi(n)) = 1$ ($e = 65537$)
5. $d = e^{-1} \pmod{\phi(n)}$

Chiffrement et déchiffrement

$$C = M^e \pmod{n}$$
$$M = C^d \pmod{n}$$

Paddings

- PKCS#1 v1.5 : 00 02 || padding || 00 || data (vulnérable)
- OAEP : padding sûr pour chiffrement
- PSS : padding recommandé pour signature

Attaques

Nom	Description
Bleichenbacher	Oracle sur padding PKCS#1 v1.5
Wiener	d petit $\rightarrow$ attaque par fractions continues
Håstad	m chiffré avec petit e sur plusieurs n
Common Modulus	m chiffré avec différents e sur même n
DFA	fault injection (bit flip) pendant le déchiffrement

3. Diffie-Hellman

Échange de clés

1. Publiques : p (premier), g (générateur)
2. Alice : $a \rightarrow A = g^a \pmod{p}$
3. Bob : $b \rightarrow B = g^b \pmod{p}$
4. Clé : $K = B^a = A^b = g^{ab} \pmod{p}$

Vulnérabilités

- Logjam : réutilisation de groupes 512/1024 bits
- Small Subgroup : clés forcées dans un petit groupe
- MITM si pas d'authentification

ECDH

- Équivalent elliptique
- Plus court, plus rapide
- X25519 standard moderne

4. Signatures

RSA Signature

- $S = H(M)^d \bmod n$
- Vérification : $S^e \stackrel{?}{=} H(M)$
- PSS recommandé

DSA / ECDSA

- $s = k^{-1}(H(m) + d \cdot r) \bmod n$
 - m, r, s publics
 - Réutilisation ou fuite de $k \rightarrow$ récupération de d
-

5. Hash / Intégrité

SHA-2

- SHA-256 : 64 rounds
- Propriétés : pré-image, 2e pré-image, collision

Attaques

Type	Description
Collision	$H(m1) = H(m2)$
Length Extension	$H(m)$ calculable si $H(m)$ connu (MD5, SHA-1, SHA-256)

HMAC

$HMAC_K(m) = H((K \text{ XOR opad}) || H((K \text{ XOR ipad}) || m))$

- Résiste à length extension
-

6. TLS

Handshake (TLS 1.2)

1. ClientHello
2. ServerHello
3. Key Exchange (RSA ou ECDH)
4. Certificat (X.509)
5. Finished (intégrité)

Versions

Version	Sécurité
SSLv2/3	Obsolète
TLS 1.0/1.1	Failles BEAST, POODLE
TLS 1.2	Sécurisée avec bonnes suites
TLS 1.3	Moderne, rapide, PFS obligatoire

Vulnérabilités

- BEAST : CBC dans TLS 1.0
 - POODLE : padding oracle SSLv3
 - Lucky13 : timing sur CBC
 - ROBOT : RSA padding oracle
-

7. JWT (JSON Web Token)

- Structure : header.payload.signature
 - Attaques classiques :
 - alg: none
 - alg: HS256 → RS256 confusion
 - Forgeries si clé publique utilisée comme clé HMAC
-

8. Outils Crypto

Outil	Utilisation
openssl	générer des clés, tester TLS
Burp Suite	modifier JWT, injections
RsaCtfTool	attaques RSA
hashcat	brute-force de hash
SageMath	calculs algébriques

9. Concepts Théoriques

- Entropie (bits de sécurité)
- AEAD = Authenticated Encryption with Associated Data
- PRF / PRP : fonctions pseudo-aléatoires
- KDF : HKDF, PBKDF2, scrypt, Argon2
- RNG / DRBG : randomness cryptographiques
- Groupes cycliques, $GF(2^8)$, courbes elliptiques
- Collisions vs pré-images vs 2e pré-images